Sorted

Security & Incident Response Policy — AURIQ LTD (Auriq Wealth)

Owner: Founder / Information Security Manager **Applies to:** the Auriq Wealth product (web app, iOS/Android apps) and all supporting infrastructure operated by AURIQ LTD. **Status:** Version 1.19, last reviewed 2026-10-05. Reviewed at least annually and after any material incident or architecture change.

This document is the company's primary security policy. It exists to satisfy our obligations as a registered agent of Finexer LTD for Account Information Services (AIS) and under UK GDPR / the Data Protection Act 2018. It covers our security controls, our incident-response process, and our data-breach procedures.

---

1. Scope & responsibilities

AURIQ LTD processes UK consumers' bank account and transaction data, obtained with the customer's explicit consent through Finexer's (and other providers') open-banking APIs, to deliver a personal financial-management dashboard (AIS only — we never initiate payments or move customer money).

- **Information Security Manager (ISM):** the founder, accountable for security, incident response, and regulator/partner notification.
- All personnel (currently founder-operated; future staff and contractors) must follow this policy and report suspected incidents immediately to the ISM.

2. Security controls (summary)

Area	Control
Bank token storage	Access/refresh tokens encrypted at rest with Fernet (AES); encryption key held only in environment/secret files, never in source control.
Secrets	All secrets injected via environment or git-ignored key files. `.env`, session/token/webhook/VAPID/APNs keys are git-ignored and never committed.
Authentication	Signed, time-limited session tokens (7-day expiry) verified on every request; sign-in only via Google or Apple verified identities; registration is restricted to an email allow list until public launch (OPEN_SIGNUP flag).
Transport security	TLS in transit; HTTPS terminated by managed platforms (Vercel/Railway) and MongoDB Atlas.
Network	Managed-platform firewalls, application-level rate limiting on auth/webhook routes, restricted CORS, and IP allow-listing of production API keys where supported (incl. Finexer).
Data store	MongoDB Atlas, access-controlled, hosted in a UK/EU region.
Backups	Encrypted nightly database backups to Cloudflare R2 with 30-day retention.
Webhooks	Signature/secret verification on inbound provider webhooks (TrueLayer: URL-embedded secret over HTTPS, no per-request signature — see `docs/security/pentest-scope-2026-09.md`; Finexer: URL-embedded secret plus HMAC-SHA256 request signing once the signing secret is configured; Stripe: SDK-verified signature).

Area	Control
	Covered by automated tests for all three (`backend/tests/test_truelayer_webhook.py`, `test_finexer_webhook.py`, `test_billing.py`).
Monitoring	Platform logs (Vercel/Railway/Atlas) and optional application error monitoring (Sentry).
Dependency & container scanning	Automated in CI (`.github/workflows/security-scan.yml`, added 2026-09): `npm audit`/`pip-audit` on every push/PR plus weekly, and a Trivy image scan of the backend container. Replaces the one-off manual audit below as the standing control; the audit log is kept as history.
Responsible disclosure	Public `security.txt` per RFC 9116 at `/.well-known/security.txt` on both UAT and production, pointing to `info@auriqltd.co.uk`.

Detailed operational security notes live in the repository's internal agent-instructions file, `DEPLOY.md`, and `ADR.md`.

Dependency audit log

Date	Surface	Tool	Result	Action
2026-09-06	Frontend (`frontend/`)	`npm audit`	8 advisories total across all dependencies (1 low, 7 high, 0 critical); 4 high in production dependencies only (`npm audit --omit=dev`: nanoid, next, postcss, sharp), the remaining 1 low and 3 high are dev-only tooling (`@babel/core`, `brace-expansion`, `browserslist`, `js-yaml`).	Recorded, not upgraded this pass. The next/postcss/sharp fixes require a Next.js major/minor jump (16.2.4 to 16.3.4) and were left for a dedicated upgrade item so the release isn't blocked.
2026-09-06	Backend (`backend/`, via a throwaway venv, not the shared `backend/.venv`)	`pip-audit`	57 known advisories (44 unique, pip-audit reports some IDs twice) across 8 packages: `aiohttp` 3.13.5, `click` 8.3.2, `cryptography` 46.0.7, `idna` 3.11, `pillow` 12.2.0, `pyasn1` 0.6.3, `python-multipart` 0.0.29, `starlette` 1.0.0. `pip-audit`'s OSV backend does not assign severity ratings; every advisory has a fix version available.	Recorded, not upgraded this pass. Follow-up item needed to review and upgrade these packages, `backend/.venv` is shared with the live UAT service so upgrades are done deliberately with a restart and verification, not as part of this audit-recording task.
2026-09-06	Frontend, after upgrade (`frontend/`)	`npm audit --omit=dev` and `npm audit`	0 vulnerabilities in production dependencies (down from 4 high: `nanoid`, `next`, `postcss`, `sharp`). Full `npm audit` (incl. dev deps) still shows 4 (1 low, 3 high) in dev-only tooling (`@babel/core`, `brace-expansion`, `browserslist`, `js-yaml`), unchanged and out of scope for this item.	Upgraded: `next` 16.2.4 to 16.3.4, `eslint-config-next` 16.2.4 to 16.3.4. Verified with `tsc --noEmit` and `next build --webpack` (both clean) before merge.
2026-09-06	Backend, after upgrade (`backend/`, via a throwaway venv, then applied to the	`pip-audit`	0 known advisories (down from 57).	Upgraded: `aiohttp` 3.13.5 to 3.14.3, `click` 8.3.2 to 8.3.3, `cryptography` 46.0.7 to 50.0.0, `idna` 3.11 to 3.15, `pillow` 12.2.0 to 12.3.0, `pyasn1` 0.6.3 to 0.6.4, `python-multipart` 0.0.29 to 0.0.31, `starlette` 1.0.0

Date	Surface	Tool	Result	Action
	shared `backend/.venv`)			to 1.3.1. `pyOpenSSL` 26.0.0 to 26.4.0 also bumped, required to resolve with the new `cryptography` pin; `fastapi` stayed at 0.136.0, its `starlette` requirement (`>=0.46.0`) did not need a bump to accept the new `starlette`. Full backend test suite (1301 tests) passed against both the throwaway venv and the shared `backend/.venv`.
2026-09-10	Backend (`backend/`, `pip-audit` run in a throwaway venv against a `pip freeze` of the live shared `backend/.venv`, 81 packages)	`pip-audit` 2.10.1	0 known advisories.	Re-run ahead of the production deploy tagged `release-20260910-1137`; no drift since the 2026-09-06 upgrade. Not upgraded, nothing to upgrade.
2026-09-10	Frontend (`frontend/`)	`npm audit --omit=dev` and `npm audit`	Production dependencies: 1 new moderate advisory, `baseline-browser-mapping` (process termination / denial of service on invalid input, GHSA-w5vr-8v7q-w6rv), pulled in transitively via `next`'s `browserslist` dependency; fix available via `npm audit fix`. Full `npm audit` (incl. dev deps): 5 advisories (1 low, 1 moderate, 3 high); the 3 high remain the same dev-only tooling as 2026-09-06 (`brace-expansion`, `browserslist`, `js-yaml`), unchanged.	Recorded, not upgraded this pass. The new moderate is a fresh advisory (published after 2026-09-06) in a package that ships as part of `next`; follow-up item needed to run `npm audit fix` and verify the build. No Critical or High in production dependencies.

Dependency audits are re-run before each production release.

3. Incident classification

Severity	Definition	Examples
Critical (P1)	Confirmed or likely unauthorised access to customer bank/personal data, or loss of the token-encryption key.	Database exfiltration, leaked `TOKEN_ENCRYPTION_KEY`, account takeover.
High (P2)	Security control failure with potential for data exposure.	Auth bypass, exposed secret, exploited vulnerability without confirmed data loss.
Medium (P3)	Contained issue, no data exposure.	Blocked intrusion attempt, dependency vulnerability, misconfiguration caught before exploitation.
Low (P4)	Minor/no risk.	Isolated failed logins, spam.

3a. Remediation SLA (A26, 2026-09)

These targets apply to a confirmed vulnerability or control failure found by internal review or a dependency/container scan, distinct from the incident *response* timings in §4, which govern an active incident already under way. A finding here may or may not also be an incident; if it is, both apply (§4's containment/notification clock starts immediately regardless of severity, remediation is tracked separately per the table below).

Severity	Acknowledge	Remediate or mitigate	Notes
Critical (P1)	Within 24 hours	Within 72 hours	A temporary mitigation (revoke a token, disable a route, roll back a deploy) that removes the exposure counts as meeting this target even if the full fix lands later; the exposure must stop within 72 hours, not just get a fix merged.
High (P2)	Within 3 business days	Within 14 days	
Medium (P3)	Within 5 business days	Within 30 days, or the next scheduled dependency/release cycle if sooner	Matches the existing dependency-audit cadence (§2's audit log; now also CI-automated, see below) — a Medium dependency finding is expected to be swept up by the next audit pass, not left open indefinitely.
Low (P4)	Best effort	Best effort, tracked on the product backlog (`TODO.md`)	Not a fixed deadline; still recorded, not silently dropped.

The ISM owns triage and severity classification, using §3's definitions. Today, as a founder-operated company, the ISM is also the only person who can implement most fixes — these targets are a commitment on effort and priority, not a guarantee that every fix ships within the window regardless of complexity; a Critical finding that needs a genuine architectural change (not a config flip or a revoke) still gets a mitigation within 72 hours and the ISM communicates a realistic timeline for the full fix.

This SLA is the answer this document backs for the Finexer compliance questionnaire's Q11 ("Security and incident controls, testing"); see `docs/compliance/finexer-agent-controls-2026-09.md` for the questionnaire answer itself (not edited by this pass) and `docs/security/pentest-scope-2026-09.md` / `docs/security/oauth-threat-model.md` for the pentest-readiness evidence Q11 can also cite.

3b. Security assessment, 20 September to 4 October 2026 (A45)

What this was. Security assessment carried out 20 September to 4 October 2026 by AURIQ LTD, of Sorted, carried out using AURIQ LTD's own testing sessions and tooling and, for the device packages and the 2026-10-04 retest, by the Information Security Manager on their own phones with the steps guided and recorded by the testing tooling, under a signed rules-of-engagement record (`docs/security/pentest-runs/roe-record.md`, authorised by the Information Security Manager, 2026-09-20). Test identities are referred to only by pseudonym (PT-A, PT-B, PT-C), except that the 2026-10-04 retest used the Information Security Manager's own production account (a recorded deviation, below); real identifiers live only in a gitignored, non-committed file. The full report is `docs/security/reports/internal-security-test-report-2026-09.md`.

Coverage: 12 of 12 work packages executed, to the extent possible without a Mac or a rooted device. Twelve work packages have now run: ten between 2026-09-19 and 2026-09-21, and the final two, both dynamic device testing, live on real devices on 2026-09-27. Each records its own sanitised evidence under `docs/security/pentest-runs/<run-id>/`:

Work package	Scope	Board item
WP1	Web shell and `/design` preview routes	A48
WP2	API inventory, credential boundaries, rate limits, error handling, CORS	A49
WP3	API tenant and object authorisation, including account deletion	A50
WP4	API input handling, uploads, business-logic ordering	A51
WP5	OAuth 2.1 authorisation server	A52
WP6	MCP connector	A53
WP7a	Android app shell, static analysis only	A54
WP7b	Android app shell, dynamic device testing (real production-pointed debug APK)	A55
WP8	iOS app shell, dynamic device testing (production TestFlight build)	A56
WP9	Finexer and TrueLayer boundary	A57
WP10	Stripe fail-closed boundary	A58
WP11	OpenRouter and Penny trust boundary	A59

WP7b and WP8 ran on 2026-09-27: WP7b against the production-pointed Android debug APK (package `co.uk.auriqltd.sorted`, SHA-256 `73bab9744ae166a94a35bcf1c05bbfc33605f225d39efd5f8e979b77b7c3fc3e`), WP8 against the production TestFlight build installed on the Information Security Manager's own iPhone. Sanitised per-test evidence and run manifests are recorded under `docs/security/pentest-runs/A55-2026-09-27/` and `docs/security/pentest-runs/A56-2026-09-27/`. A number of instrumented or Mac-only sub-steps within those two packages were not tested in this round, because this round did not have the equipment: `IOS-01`, `IOS-06`, the Keychain and file-protection halves of `IOS-02`, the `IOS-05` scheme-collision tie-break, and the Frida- or root-dependent Android sub-steps listed in the "Deferred" table at the end of `A55-2026-09-27/records.md` (memory inspection, instrumented UI automation, WebView content-debugging fuzzing, and similar). They need a Mac, a rooted device or instrumentation that was not available, and they are carried as Blocked or not tested, never as passed. With those two packages run, coverage is 12 of 12 work packages executed to the extent possible without that equipment.

On 2026-10-04 the Information Security Manager retested the A120, A121 and A122 fixes on their own Android phone and iPhone against production, with the steps guided and recorded by the testing tooling; the record is `docs/security/pentest-runs/A60-2026-10-04/`. It used the Information Security Manager's own production account instead of the pseudonymous identity PT-A (a deviation the Information Security Manager authorised), and individual checks are not attributed to the run's two production builds except where server logs place them.

WP0 (A47) built the evidence and rules-of-engagement harness ahead of this round's testing. WP12 (A60) specified a second review pass with tooling different from the testing sessions. The Information Security Manager decided on 2026-10-04 not to perform it; this is a recorded deviation. The review that was performed is a separate review pass over the evidence on 2026-10-04 (WP12 review, PASS on second pass), which used the same tooling as the testing sessions and so was not independent of them. Final severities remain the ISM's to confirm per section 3a.

Findings. These were reported first and fixed after, per the Information Security Manager's deliberate choice (see each item's own board note). Twenty findings were first raised in the 2026-09-19 to 2026-09-21 round and five

more (A118, A119, A120, A121, A122) in the WP7b/WP8 device testing on 2026-09-27, twenty-five in all. As of 2026-10-04:

- Fifteen of the twenty were fixed on `main` by 2026-09-22 with regression tests, shipped to production on 2026-09-27 (the four High findings A82, A83, A84, A91 and the other eleven all in `release-20260927-0947`) and retested the same day on the `release-20260927-1844` build (board item A112, `docs/security/pentest-runs/A112-2026-09-27/`): fourteen confirmed Fixed (A88, A89 and A95 by source read only; the live-deletion halves of A82, A83 and A84 were source-confirmed that day and then retested live on 2026-10-04; see the tables below) and A80 Partially fixed.
- A120, A121 and A122 were fixed on `main` on 2026-09-29, first shipped in `release-20261001-2038`, and retested on device on 2026-10-04 (`A60-2026-10-04`).
- A118 has its server-side logout revocation in production; the device re-check of on-disk residue has not been run.
- A119 is closed: debug build only, with the signed release APK verified on 2026-09-28 as not remotely inspectable.
- Five (A73, A77, A79, A81, A94) remain open.
- Two further pre-documented items are not in the counts above: the Android backup High (A129, fixed, listed in the High table) and the `AND-08` scheme-exclusivity Low (no board item, listed in the Low table).

Severities use section 3's bands and are provisional pending the ISM's sign-off and the review pass described below, which was not independent of the testing.

High (P2): six findings, no Criticals.

Item	Finding	Status
A82	Account deletion never revokes the Finexer consent first, orphaning it at the provider	Fixed on main 2026-09-22 (2488763e), regression-tested; released to production 2026-09-27 (`release-20260927-0947`, confirmed still present in `release-20260927-1844`); source-confirmed 2026-09-27 (A112, live retest Blocked by an expired credential); Fixed, retested live on production 2026-10-04 (`A60-2026-10-04`, `API-15`); the Finexer dashboard was not viewed in that run, so the provider-side revoke is evidenced by the response and the deployed source
A83	`GET /connections` does not list live Finexer connections, hiding the very connection A82's disconnect-first step needs	Fixed on main 2026-09-22 (c35ac008), regression-tested; released to production 2026-09-27 (`release-20260927-0947`, confirmed still present in `release-20260927-1844`); retested 2026-09-27: the `GET /connections` listing half confirmed Fixed live (Pass); the disconnect-before-delete half source-confirmed 2026-09-27, then Fixed, retested live on production 2026-10-04 (`A60-2026-10-04`, `API-15`)
A84	A deleted account's session token is not invalidated and remains usable for up to 7 days; it has been shown able to write persistent data that reattaches if the account is later recreated with the same email	Fixed on main 2026-09-22 (40fed391), regression-tested; released to production 2026-09-27 (`release-20260927-0947`, confirmed still present in `release-20260927-1844`); source-confirmed 2026-09-27 (A112, live retest Blocked); Fixed, retested live on production 2026-10-04 (`A60-2026-10-04`, `API-15`): the session token was rejected (401) immediately after deletion

Item	Finding	Status
A91	The MCP connector's output masking is structural only (drops fields by shape) and never sanitises the content it keeps, so an instruction-shaped string in a merchant name, recurring-series description or insight trigger reaches the connecting external assistant unmodified: a live prompt-injection surface with no content-level mitigation. The connector is off in production by design (A17), so this exposure is UAT-only today; it must be fixed before the connector is enabled in production (board item F1, Finexer design sign-off, still open), it is not actively exploitable in production now	Fixed on main 2026-09-22 (9c5b7ef9), regression-tested; released to production 2026-09-27 (`release-20260927-0947`, confirmed still present in `release-20260927-1844`); retested 2026-09-27 on UAT (MCP connector off in production by design, A17), confirmed Fixed live
A129	Android backup gap (the pre-documented `AND-01` / `AND-02` storage-and-backup finding): `android:allowBackup="true"` let a passwordless `adb backup` of the debug build capture the session token. Rated High (P2) per `PENTEST-METHODOLOGY.md` section 8.4	Remediated: fixed under A129 (`cbb05f3c`, integrate commit), `android:allowBackup="false"` plus `fullBackupContent` and `dataExtractionRules` exclude-everything rules for cloud backup and device transfer; first shipped in `release-20261004-1833`. Verified 2026-10-04 by package-flag inspection (the Information Security Manager's `dumpsys package` on the production APK installed 2026-10-04 19:41:47 BST (built from `release` after `release-20261004-1833`) shows `flags=[ HAS_CODE ALLOW_CLEAR_USER_DATA ]`, no `ALLOW_BACKUP`, no `DEBUGGABLE`); an `adb backup` extraction was not re-run. Defence in depth: A123 moved the token into Keystore/Keychain-backed storage (keys not backed up) and A118 revokes sessions on logout
A121	The iOS biometric privacy lock was bypassable: with the lock engaged (cold start and via notification tap), the nav bar and Penny suggestion chips were tappable behind the visual overlay, and a chip tap rendered live safe-to-spend and upcoming-bills figures with no authentication. Android's overlay held	Found in device testing 2026-09-27; fixed on `main` 2026-09-29 (`eae3207e`, integrate commit); in production since `release-20261001-2038`; retested on device 2026-10-04 (`A60-2026-10-04`): Pass on both phones, with the app open and from a cold start via a notification tap

A82, A83 and A84 are one deletion-lifecycle root cause: account deletion does not disconnect a customer's bank connection before erasing local data. A91 is unrelated to that workstream. A121, found in the 2026-09-27 device testing, is unrelated to either.

A129 names both the finding row (the pre-documented `AND-01` / `AND-02` backup gap) and its fix item (board item A129).

Medium (P3)

Item	Finding	Status
A73	OAuth consent page under-emphasises the true redirect host relative to the connector's self-reported name	Open
A74	Refresh-token rotation does not cascade-revoke the sibling access token from the same grant (pre-documented gap)	Fixed on main 2026-09-22 (eac94538); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build); retested 2026-09-27 on UAT (the OAuth server is not registered on production), confirmed Fixed live (A112)

Item	Finding	Status
A79	Bank narrative text is sent to OpenRouter for categorisation and Penny read tools, unredacted (pre-documented design concern)	Open
A88	Finexer consent callback accepts a missing `state` parameter (defence-in-depth gap only; no cross-account path exists because binding is fixed at session-gated consent creation)	Fixed on main 2026-09-22 (683078c8); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build); retested 2026-09-27, confirmed Fixed by source read (A112)
A89	Webhook path-secret comparison is not constant-time (no practical timing exploit identified; the secret also functions as a long random URL segment)	Fixed on main 2026-09-22 (f4983f8e); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build); retested 2026-09-27, confirmed Fixed by source read (A112)
A92	Production's proxy chain does not strip a caller-supplied `X-Real-IP`/`X-Forwarded-For` header, so any IP-keyed rate limit on production can be bypassed by rotating the header. Triaged to Medium, down from the board's own initially proposed High: there is no password login to brute-force behind this, and per-user (not IP-keyed) limits on data routes are untouched	Fixed on main 2026-09-22 (d5fbdfe1); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build) after its A110 gate (trusted-proxy hop handling, done 2026-09-24); retested 2026-09-27, confirmed Fixed live (A112)
A95	`GET /logo/{domain}` carries no rate limit at all, not even the general IP catch-all, so an unlimited caller can drive cost through the server-side image proxy	Fixed on main 2026-09-22 (aeadb348); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build); retested 2026-09-27, confirmed Fixed by source read (A112)
A118	After logout, the Android session token value is still recoverable on disk (LevelDB append-only storage)	Found in device testing 2026-09-27; server-side logout revocation (sign out everywhere) fixed on `main` 2026-09-29 (`24e79129`, integrate commit) and in production since `release-20261001-2038`; the device re-check of on-disk residue has not been run (the storage root cause is follow-up A123)
A119	On the Android debug build the WebView is remotely inspectable, and the authenticated DOM plus Capacitor bridge are reachable behind the lock overlay; the deciding follow-up is to verify the signed release APK disables WebView content debugging	Closed 2026-09-28: debug build only. The signed release APK was decompiled and verified not remotely inspectable; closed by static verification, not by a device retest
A132	Commitments goal-pot account lookups (`_live_balance`, `_account_name`, `_pot_kind`, and so `_build_pots` on goal create and update) were not filtered by user, so a goal's pot could reference, and read the balance or kind of, an account id the caller does not own. Pre-existing; found 2026-09-30 by the G176 review. No exploit was attempted and no live records were queried	Fixed on the A132 branch: every lookup now carries `user_id` in the query; a pot naming an account the caller does not own or that does not exist is a 404 with one shared body; a stored pot pointing at a foreign account reads as unavailable. Regression-tested (`backend/tests/test_commitments_pot_scoping.py`). Not yet merged or released

Low (P4)

Item	Finding	Status
A76	`/design/*` preview routes are publicly indexable (no `robots.txt`/`X-Robots-Tag`)	Fixed on main 2026-09-22 (e7621167); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build); retested 2026-09-27, confirmed Fixed live (A112)
A77	The native-purchase `X-Client-Platform` header check can be bypassed by omitting it (billing is not live; pre-documented)	Open
A80	No global/service-wide OpenRouter spend ceiling exists, only a per-user monthly allowance	Partially fixed. Fixed on main 2026-09-22 (7bea0094); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build); retested 2026-09-27 (A112): the ceiling mechanism is in code, but the environment variable that enables it was unset on both production services that day, so no ceiling was enforced (the Information Security Manager's operational decision; not re-checked since)
A81	The per-user LLM allowance check fails open, not closed, on an internal lookup error (documented, deliberate trade-off)	Open
A85	`PATCH /preferences` has no optimistic-concurrency check and accepts an unadvertised field (mass assignment)	Fixed on main 2026-09-22 (4b866395); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build); retested 2026-09-27, confirmed Fixed live (A112)
A86	The commitment state machine allows out-of-order transitions and has no create-time idempotency check	Fixed on main 2026-09-22 (1f8a318d); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build); retested 2026-09-27, confirmed Fixed live (A112)
A90	The MCP connector's `initialize` handler never validates or negotiates the client's requested protocol version	Fixed on main 2026-09-22 (141b057c); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build); retested 2026-09-27: live on UAT (envelope validation), source review (version negotiation) (A112)
A93	An unhandled NUL byte in a search query parameter crashes one endpoint with a 500 (no data leaked)	Fixed on main 2026-09-22 (4e0093e0); in production from `release-20260927-0947` (A112 retested the `release-20260927-1844` build); retested 2026-09-27, confirmed Fixed live (A112)
(none)	Android scheme-exclusivity for the bare `wealthdash://` custom scheme: Android has no OS-level exclusivity, so a competing app can be offered alongside Sorted (`AND-08`, static in WP7a, confirmed live in WP7b); the callback carries no code or token, so the practical exploit path is closed off	Open, pre-documented design gap, no board item; severity Low, no remediation short of a verified `https://` App Link
A120	Push device registration survived logout on both Android (FCM) and iOS (APNs): the unregister call was never made, and no server-side logout route existed to unregister the device token either	Found in device testing 2026-09-27; fixed on `main` 2026-09-29 (`44311669`, integrate commit); in production since `release-20261001-2038`; retested on device 2026-10-04 (`A60-2026-10-04`): after sign out everywhere, test pushes no longer arrive on either phone (Pass); the resume-after-sign-in half passed on re-run, after one earlier Android Fail tracked as follow-up A138 (open, intermittent)
A122	The app-switcher/recents snapshot showed live financial figures even with the biometric lock enabled, confirmed on both iOS and Android	Found in device testing 2026-09-27; fixed on `main` 2026-09-29 (`bdbda0af`, integrate commit); in production since `release-20261001-2038`; retested on device 2026-10-04 (`A60-2026-10-

Item	Finding	Status
		04`): the app-switcher card is covered on both phones and a screenshot is blocked on Android while the lock is on (Pass)

Informational

Severity bands: section 3's four bands (Critical, High, Medium, Low) apply to every finding above. The Informational band comes from the testing methodology (`docs/security/PENTEST-METHODOLOGY.md` section 8.3): a verified fact or hardening opportunity with no demonstrated adverse outcome and no P1-P4 SLA, used here for A94. A76 is listed as Low in the table above (the A48 `DSGN-04` record scored the same crawlable-preview exposure Informational, a business-confidentiality risk and not a security-boundary breach); the register's Low is the more conservative rating, and the board's rating governs.

Item	Finding	Status
A94	A dead, unreachable authorisation branch in `current_user` for an out-of-scope bot credential; access is still correctly denied elsewhere, so this is not itself a weakness	Open

A75 (a frontend-only distribution flag with no backend equivalent) is a product-intent question for the Information Security Manager, not a severity-rated security finding. A92's board priority tag is p2, which is a work-scheduling priority, not its security severity; its severity, per the triage above, is Medium.

Headline. No Critical findings. Six High findings in total (four API and MCP, one iOS lock bypass, one pre-documented Android backup gap), all fixed in production. Retest status differs by finding and is stated below: the four API and MCP fixes were retested on 2026-09-27, and the three deletion fixes (A82, A83, A84), which that day could be confirmed by source read only, were then retested live on production on 2026-10-04 (`API-15`), the iOS lock bypass was retested on both phones on 2026-10-04, and the Android backup fix was verified on 2026-10-04 by package-flag inspection only (the `adb backup` extraction was not re-run). Four (A82, A83, A84, A91) were fixed on `main`, merged 2026-09-22, each with regression tests: the deletion-lifecycle root cause (A82, A83, A84) and A91, the MCP prompt-injection gap, which remains UAT-only until the connector is enabled in production (gated on board item F1, the written Finexer design sign-off, still open, not F2, which is the OAuth server and is already done). All four shipped to production on 2026-09-27 (`release-20260927-0947`) and were retested the same day (board item A112, `docs/security/pentest-runs/A112-2026-09-27/`): A83's `GET /connections` listing half and A91 were confirmed Fixed live; A82, A83's disconnect-before-delete half and A84 were source-confirmed that day, because the live `API-15` retest was Blocked by an expired test credential; that step was then retested live on production on 2026-10-04 with the disposable identity PT-C (`A60-2026-10-04`): deletion revoked the connection first and the same session token was rejected immediately afterwards (the Finexer dashboard was not viewed, so the provider-side revoke is evidenced by the response and the deployed source). A fifth is **A121**: the iOS biometric privacy lock was bypassable, found in device testing on 2026-09-27, fixed on 2026-09-29, shipped in `release-20261001-2038` and retested on both phones on 2026-10-04 (Pass). The sixth is the Android backup gap (`AND-01` / `AND-02`, pre-documented, High), fixed under A129 (`cbb05f3c`, first shipped in `release-20261004-1833`) and verified on 2026-10-04 by package-flag inspection only; the `adb backup` extraction was not re-run. Of the remaining twenty Medium, Low and Informational findings: the eleven first-round fixes were retested on 2026-09-27 (ten confirmed Fixed, A80 Partially fixed); A120 and A122 were fixed, shipped and retested on device on 2026-10-04; A118 has its server-side revocation in production with the on-device re-check outstanding; A119 is closed (debug build only); and five (A73, A77, A79, A81, A94) remain open.

Production status as of 2026-10-04. Every fix listed above is in production: the first-round fixes since 2026-09-27 (`release-20260927-0947`; A112 retested the `release-20260927-1844` build) and the device-round fixes (A118, A120, A121, A122, plus follow-up A123, which moves the native session token into platform secure storage) since `release-20261001-2038`. The A112 retest of the fifteen first-round fixes and the 2026-10-04 on-device retest of A120, A121 and A122 are recorded under `docs/security/pentest-runs/A112-2026-09-27/` and `docs/security/pentest-runs/A60-2026-10-04/`. The deletion-lifecycle retest (`API-15`: deletion revokes the Finexer consent, the connections list shows Finexer, and both the deleted account's session token and its OAuth tokens are rejected) ran on 2026-09-27; its destructive half was Blocked by an already-expired test credential that day, and was retested live on 2026-10-04 (`A60-2026-10-04`, `API-15`, PT-C). The live test covered the connection revoke and the session token; OAuth tokens were not exercised live (the connector is off in production). A106, opened during that fix, is a narrower residual gap in the same lifecycle: if Finexer is down at the moment of revoke, the consent is orphaned locally with no retry record; it is not rated High. Remediation follow-ups, not new findings: A123 (device retest pending) and A138 (push re-registration after sign-in, intermittent, open). Separately, the MCP connector remains disabled in production (A17): an anonymous `initialize` call on 2026-09-23 returned 401 with no `WWW-Authenticate` challenge on both the Vercel-fronted path and the direct Railway host, while UAT correctly advertises the challenge; enabling it in production stays gated on F1, Finexer's written design sign-off.

Scope caveats, stated plainly. This round has real, acknowledged gaps that a reader of the findings list above should not have to infer:

- The planned second review pass with different tooling (WP12) was not performed (Information Security Manager decision, 2026-10-04), so the testing has not been reviewed with different tooling. A separate review pass using the same tooling as the testing was performed on 2026-10-04 (WP12 review, PASS on second pass); it was not independent of the testing.
- The 2026-10-04 live account-deletion retest (`API-15`) did not view the Finexer dashboard, so the provider-side revoke is evidenced by the response and the deployed source, and OAuth tokens were not exercised live.
- Four coverage items are not Pass: `WEB-03` and `WEB-05` (Blocked, the live production run was intercepted by Vercel's bot-verification challenge; retest recommended with a real browser session), `WEB-02`'s storage-inspection sub-component (Inconclusive, an availability event contaminated the one attempt) and `AND-04`'s user-CA leg (Inconclusive, Android would not trust the test CA; settled by static reading only). Owner for all four is the Information Security Manager. See the report's section 6.
- `TL-01`, `TL-03`, `TL-05` and `TL-04`'s live-write half were Not run, because TrueLayer is being removed from production (A67).
- Two Finexer/TrueLayer cases could not be completed: `FIN-06` (webhook payload retention) and the accepted-delivery live halves of `FIN-01` and `TL-02`, because this testing session has no production database read path and no provider-approved sandbox consent exists.
- The instrumented and Mac-only sub-steps of WP7b and WP8 were not tested in this round, because this round had no Mac, rooted device or instrumentation; they are carried as Blocked, not passed.
- The Android token-at-rest re-check (A118, A123) was not run on 2026-10-04: it needs a debug build. The backup half (A129) was verified by package-flag inspection only; an `adb backup` extraction was not re-run. A123 staying signed in across restarts is pending the Information Security Manager's result.
- A temporary `OPEN_SIGNUP` window on production (opened and closed on 2026-09-19, board item A63, to create test identities) was not audited for unexpected registrations during the roughly 36-minute window it was open.

This section is the evidence Q11 ("Security and incident controls, testing") cites for the security testing programme; see `docs/compliance/finexer-agent-controls-2026-09.md` for the questionnaire answer and `docs/security/pentest-runs/` for the sanitised per-run records.

Sign-off. Signed off by the Information Security Manager, 2026-09-21, given as a written attestation ('Happy to sign this'), not a handwritten or cryptographic signature. Status update 2026-09-23 recorded by AURIQ LTD's testing tooling for the Information Security Manager's confirmation; the per-finding statuses above reflect `main` and the `release` branch as of that date. Further update 2026-09-27 (board item A117): WP7b and WP8 device testing was executed live, and findings A118 to A122 were folded into the coverage and findings sections above; recorded by AURIQ LTD's testing tooling for the Information Security Manager's confirmation. Further update 2026-10-04 (board item A60): the A120, A121 and A122 fixes were retested on device and the A118 to A123 statuses recorded above. The report is version 1.0.1, dated 2026-10-04 and revised 2026-10-05; the WP12 review (a separate review pass using the same tooling as the testing, so not independent of it, 2026-10-04) passed on its second pass.

4. Incident response process

Every incident follows this lifecycle. The ISM leads; timings below are targets.

1. **Detect & record** — Identify via monitoring, provider (Finexer) notification, user report, or internal discovery. Open an incident record with timestamp, reporter, and initial description.
2. **Contain** — Stop the bleeding. As applicable: revoke affected bank access tokens; revoke affected Finexer consents (`DELETE /consents/{id}`); disable affected accounts/allowlist access; rotate compromised secrets (`SESSION_SECRET`, `TOKEN_ENCRYPTION_KEY`, webhook secrets, provider API keys); block malicious IPs; take affected services offline if necessary.
3. **Assess scope** — Determine what data, which customers, and which systems are affected, and whether personal data was accessed, altered, or lost. Classify severity (§3).
4. **Notify** —
    - **Finexer:** report any breach of our systems, non-compliance, money-laundering attempt, or other incident **as soon as practicable and within 24 hours** of becoming aware, per our agency agreement.
    - **ICO:** report a personal-data breach **within 72 hours** of becoming aware where it poses a risk to individuals' rights and freedoms.
    - **Affected individuals:** notify without undue delay where the breach is likely to result in a **high risk** to their rights and freedoms.
    - Maintain an internal record of the incident regardless of whether external notification is required.
5. **Remediate** — Eradicate the root cause, restore from clean backups if needed, apply patches/config fixes, and verify the fix.
6. **Post-incident review** — Within 5 working days of closure, document root cause, timeline, impact, actions taken, and preventative measures. Feed lessons back into controls and this policy.

5. Data-breach procedures

A **personal data breach** is any breach of security leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to customer personal or financial data.

- Any suspected breach is treated as an incident (§4) and, if it involves personal data, triggers the ICO 72-hour assessment and the Finexer 24-hour notification.
- The ISM maintains a breach register recording: date/time of discovery, nature of the breach, categories and approximate number of individuals and records affected, likely consequences, and measures taken.
- Where notification thresholds are met, notifications include the nature of the breach, contact point, likely consequences, and mitigating measures.

6. Data retention

AURIQ LTD retains customer data only for as long as necessary to provide the service and to meet legal obligations, in line with the UK GDPR storage-limitation principle. This section defines our retention periods and deletion mechanisms.

Status: DRAFT. Periods marked `[CONFIRM]` are provisional defaults pending founder sign-off. The automated purge jobs below now enforce the account/transaction retention limits, running nightly at 03:30 UTC as an arq cron job (`task_retention_sweep`), in addition to the user-initiated mechanisms.

Data category	Retention period	Mechanism
Bank account & transaction data	Retained while the customer's account is open and the open-banking consent is active. Deleted within `[CONFIRM: 30]` days of account closure, consent withdrawal or expiry, or after `[CONFIRM: 12]` months of account inactivity.	User-initiated (account deletion / bank disconnect) plus a nightly automated sweep: a bank connection is auto-purged 30 days after its consent expires or is withdrawn if the customer never disconnected it themselves, and a whole account is auto-purged after 12 months with no sign-in.
Open-banking consent records (status, timestamps)	Life of the connection plus `[CONFIRM: 12]` months for audit, then deleted.	Consent records.
Encrypted bank access tokens	Deleted immediately on bank disconnect or account deletion; overwritten on consent renewal.	Cascade on disconnect + remote consent revoke.
AI chat sessions	7 days.	Automatic TTL.
Savings-insight caches	30 days.	Automatic TTL.
Webhook event logs	30 days.	Automatic TTL.
Database backups	30-day rolling window (nightly encrypted backups to Cloudflare R2).	Automatic prune.
Records required by law or regulator (if any)	Statutory minimum, then deleted.	Manual review.

Deletion mechanisms:

- **Right to erasure:** a customer can delete their entire account, removing their records across all data stores; deletions cascade to their accounts and transactions.

- **Bank disconnect:** removes that connection's accounts and transactions and revokes the provider (e.g. Finexer) consent.
- **Backups:** data belonging to deleted customers ages out of encrypted backups within the 30-day backup window.
- **Suppression record on owner removal (E12):** when the account owner removes a person from the People page, every record is erased as for a self-service deletion, and one minimal row is kept in the sign-up allow list holding only the normalised address key and a "revoked" status (the email, note and inviter fields are dropped). It is a legitimate-interest suppression record, so a removed person cannot sign up again under open sign-up without the owner restoring them. The owner's audit trail keeps the action with the address masked, and earlier entries for that person are masked at the same time.
- **Accounts that signed up before invite-only mode (E13):** an account created under open sign-up has no allow-list row, so invite-only sign-in refuses it. The owner allows these accounts in one step from the People page (or the equivalent script), which adds an ordinary allowed row for each, never touching the owner or an existing row; each can be revoked from the page afterwards, and the action is recorded in the audit trail with a count only.

Retention periods are reviewed at least annually.

7. GDPR compliance

Personal information is processed in line with the seven UK GDPR principles:

- **Lawfulness, fairness & transparency** — bank data is accessed only on the customer's explicit open-banking consent, captured on the provider's (Finexer) and bank's hosted consent pages before any data is retrieved.
- **Purpose limitation** — data is used solely to provide the account-information dashboard and insights the customer signed up for; it is never sold and never used for marketing.
- **Data minimisation** — only the data needed is retrieved (typically the last ~90 days of transactions) and the minimum is shared with sub-processors (e.g. only merchant name/description for categorisation).
- **Accuracy** — transaction data is sourced directly from the customer's bank via open banking, and customers can view and re-categorise their own data in-app.
- **Storage limitation** — data is retained only as long as necessary under our Data Retention Policy (§6) and deleted on account closure or request.
- **Integrity & confidentiality** — bank tokens are encrypted at rest (AES/Fernet), data is encrypted in transit (TLS), and access is restricted and access-controlled.
- **Accountability** — our security, incident-response and retention practices are documented in this policy.

ICO registration is complete (registration number ZC214737). Open item to address (draft): publish the customer-facing privacy notice to fully satisfy the transparency principle.

Privacy notice & consent withdrawal

We will publish a customer-facing privacy notice (accessible in-app and on the website) covering: who we are and how to contact us; the personal and financial data we process; the lawful basis (explicit consent) and purposes; the sub-processors we share data with; retention periods (see §6); customers' rights (access, rectification, erasure, portability, objection, and withdrawal of consent); and how to complain to the ICO.

Customers can withdraw consent and have their data removed at any time, using mechanisms already built into the app:

- **Disconnect a bank** — revokes the open-banking consent with the provider (e.g. Finexer) and deletes that connection's accounts and transactions.
- **Delete account** — full erasure of the customer's data across all data stores.

Open item (draft): the privacy notice described above is documented here but is NOT yet published as a customer-facing page. Until it is published and linked (login screen, bank-connect step, and settings), the app does not yet fully satisfy the transparency requirement. Action: publish a `/privacy` page and link it.

8. Contacts

- **Internal (ISM):** info@auriqltd.co.uk / 07398773162.
- **Finexer:** TBC.
- **ICO:** report at ico.org.uk or the ICO breach helpline within 72 hours.

9. Review

This policy is reviewed at least annually, and after any material incident, change of provider, or significant change to the system architecture. Version history is tracked below.

Version	Date	Change
1.0	2026-08-09	Initial policy.
1.1	2026-08-09	Added Data retention section (draft).
1.2	2026-08-09	Added GDPR compliance section (draft).
1.3	2026-08-09	Documented privacy notice & consent-withdrawal process (draft; page not yet published).
1.4	2026-08-14	Recorded ICO registration; drafted Privacy Policy and Terms & Conditions.
1.5	2026-09-06	Removed legacy PIN login; masked reconnect state; first recorded dependency audit.
1.6	2026-09-06	Automated retention sweeps (connections 30 days after consent ends, dormant accounts after 12 months).
1.7	2026-09-06	Dependency upgrades from the audit (Next 16.3.4; aiohttp, pillow, cryptography, starlette, pyasn1, python-multipart, idna, click).
1.8	2026-09-08	Contact address changed to info@auriqltd.co.uk.
1.9	2026-09-10	Fresh dependency audit ahead of the production deploy (release-20260910-1137); recorded below.

Version	Date	Change
1.10	2026-09-14	A26 pentest-readiness pass: added the remediation SLA (§3a); dependency/container scanning moved from a one-off manual audit to CI (`.github/workflows/security-scan.yml`); added public `security.txt` (RFC 9116); OAuth 2.1 authorisation server threat-modelled for the first time (`docs/security/oauth-threat-model.md`) and a concurrent-redemption race in the authorization-code and refresh-token exchange fixed; added webhook replay/forgery tests for TrueLayer (previously untested) alongside the existing Finexer/Stripe coverage; confirmed bank tokens are Fernet-encrypted at rest for TrueLayer connections (read-only check against live UAT data) and found Yapily's dormant consent-token storage is not (flagged, not fixed — see `docs/security/pentest-scope-2026-09.md`); added a CI guard against `/design` preview routes reaching real data, and found six existing preview files already do (flagged, not fixed, same document).
1.11	2026-09-21	A45 draft: added §3b recording the security testing round of 2026-09-19/20 (seven work packages, findings by severity, all currently open) and its scope caveats, folded into Q11 as a proposed answer pending the Information Security Manager's sign-off.
1.12	2026-09-21	A45 draft, updated: three more work packages executed (WP2/A49, WP6/A53, WP10/A58), coverage now 10 of 12 (WP7b Android dynamic and WP8 iOS dynamic remain deferred); six new findings folded in (A90, A91, A92, A93, A94, A95); headline now four High findings (the deletion-lifecycle three plus A91, an MCP prompt-injection gap, UAT-only until the connector is enabled in production); Q11 draft updated to match.
1.13	2026-09-21	A45 correction: A91's pre-production gate was wrongly cited as board item F2 (the OAuth 2.1 authorisation server, done 2026-09-08); the correct gate is F1, the written Finexer design sign-off, still open. Fixed in the A91 finding row and the headline.
1.14	2026-09-23	A107: fifteen of the twenty §3b findings, including all four High findings (A82, A83, A84, A91), are now fixed on `main` with regression tests; updated the intro, headline and every fixed finding's Status cell with date and commit, and added a "Production status as of 2026-09-23" paragraph recording that production release (A92 gated on A110), the deletion-lifecycle production retest and WP12 (A60) are all still pending. Five findings (A73, A77, A79, A81, A94) remain open.
1.15	2026-09-27	A117: WP7b (Android, A55) and WP8 (iOS, A56) dynamic device testing executed live on real devices; coverage corrected from 10 of 12 to 12 of 12 work packages (to the extent possible without a Mac or a rooted device, remaining sub-steps not tested in that round); five new findings folded in (A118, A119, A120, A121, A122); headline corrected to five High findings, since A121 (iOS biometric-lock bypass exposing live financial data) is not yet remediated, distinct from the four earlier High findings which remain fixed on `main` pending production release. Evidence under `docs/security/pentest-runs/A55-2026-09-27/` and `docs/security/pentest-runs/A56-2026-09-27/`.
1.16	2026-09-28	A117 correction: version 1.15 (and the pre-existing §3b intro/headline/Production-status text it left unchanged) stated that none of the four High fixes (A82, A83, A84, A91) had reached production and that no production retest had run; both were false by the time 1.15 was written. All four shipped to production 2026-09-27 in `release-20260927-0947` (confirmed still present in `release-20260927-1844`, `git tag --list 'release-*'`), nine hours before 1.15's own commit, and were retested the same day (board item A112, `docs/security/pentest-runs/A112-2026-09-27/`). Corrected the §3b intro paragraph, the four High findings' Status cells, the Headline, and the "Production status" paragraph to record the A112 outcome per finding: A83's `GET /connections` listing half and A91 confirmed Fixed live; A82, A83's disconnect-before-delete half and A84 confirmed Fixed by source read only, the live `API-15` retest itself Blocked by an already-expired test credential, a follow-up live pass is still owed. Q11 and the A111 report wording are not touched by this row; those are separate, unreviewed follow-ups.
1.17	2026-10-04	A60: §3b brought in line with version 1.0 of the security test report (`docs/security/reports/internal-security-test-report-2026-09.md`). Recorded the 2026-10-04 on-device retest (`docs/security/pentest-runs/A60-2026-10-04/`): A120, A121 and A122 fixed, in production since `release-20261001-2038` and retested on both phones; A118 server-side revocation in production with the on-device residue re-check not yet run; A119 closed (debug build only); first-round fixes updated with A112's 2026-09-27 retest outcomes (A80 Partially fixed). Follow-ups A123 and A138 noted. Added the pre-documented Android backup High (`AND-01` / `AND-02`, fixed under

Version	Date	Change
		A129, verified by package-flag inspection). Reworded the testing description as a security assessment carried out by AURIQ LTD, 20 September to 4 October 2026. Sub-steps that could not be run (no Mac, rooted device or instrumentation) are carried as not tested. WP12 recorded as a review with the same tooling as the testing, the planned second pass with different tooling not performed (Information Security Manager decision, 2026-10-04); reviewed 2026-10-04, PASS on second pass.
1.18	2026-10-04	A60: live `API-15` account-deletion retest ran on production with the disposable identity PT-C (`docs/security/pentest-runs/A60-2026-10-04/`), superseding A112's Blocked, source-only verdict. A82, A83 (destructive half) and A84 updated to Fixed, retested live; the Finexer dashboard was not viewed. Report finalised as version 1.0.
1.19	2026-10-05	A60: Wording of roles revised; no personal names; no change to findings, statuses or evidence.

Sorted is a trading name of AURIQ LTD. AURIQ LTD is acting as an agent of Finexer LTD, which is authorised by the Financial Conduct Authority under the Payment Services Regulations 2017, firm reference number 925695, as an Authorised Payment Institution to provide account information services and payment initiation services.